

Achieving DPDPA Baseline Compliance for a Telemedicine Platform

A Blueprint for Indian Digital Health Platforms navigating the **Digital Personal Data Protection Act (DPDPA), 2023** — covering seamless integration of Section 5 Notices, Section 6 Consent architectures, and Section 10 Significant Data Fiduciary (SDF) mandates.

DIGITAL HEALTH COMPLIANCE

DPDPA 2023



The Telemedicine Data Landscape in India

Navigating the Sensitive Data Matrix

A representative telemedicine platform like **Arogya Digital** handles 1.5 million consults annually — processing electronic health records (EHR), diagnostics, and multi-modal patient data at scale. Understanding exactly what data flows through the system is the essential first step toward compliance.

Personally Identifiable Information

Name, phone number, government IDs (Aadhaar/PAN for billing and verification purposes).

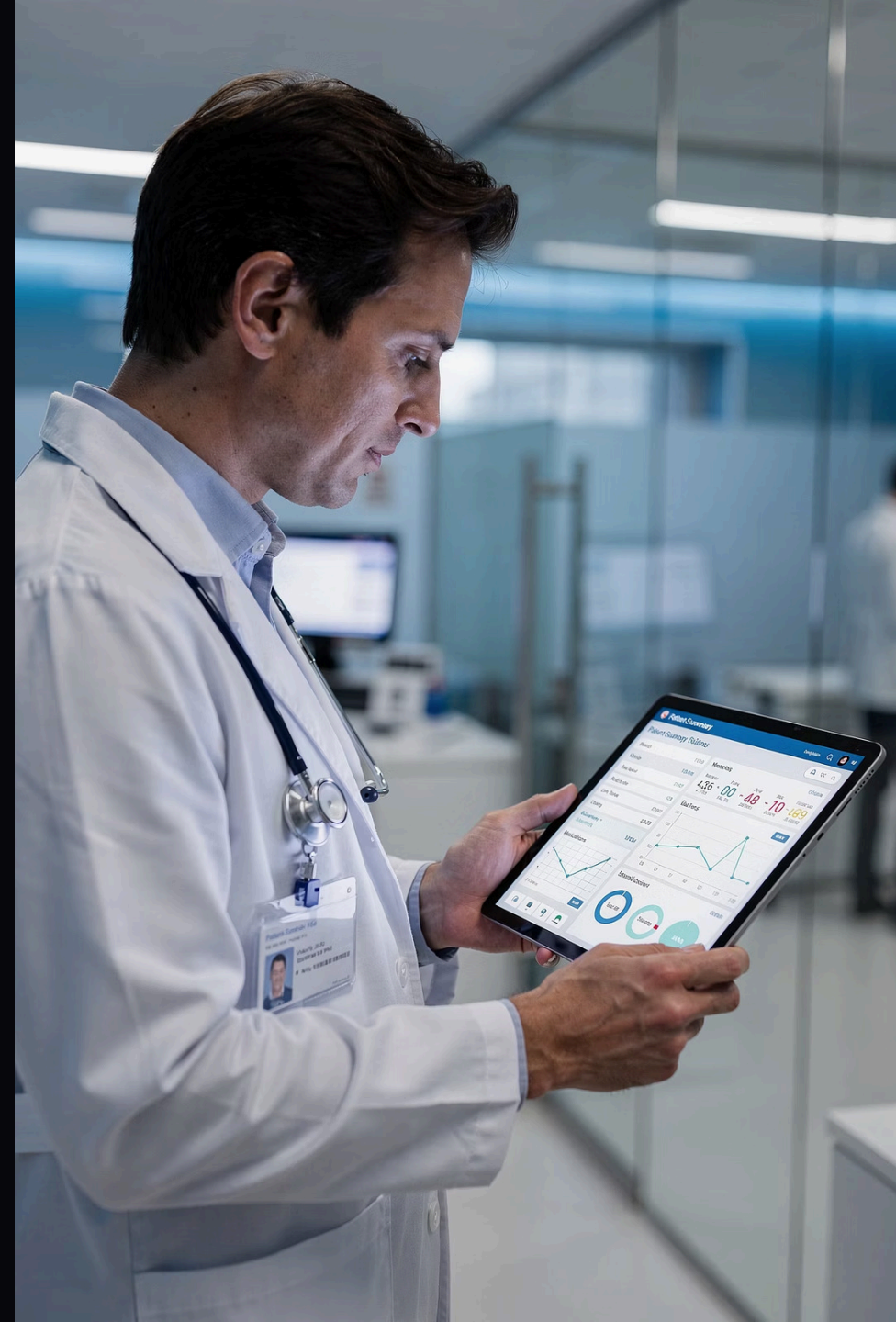
Health Data

Prescriptions, diagnostic reports, symptoms, medical history, and video/audio consultation logs.

Technical Data

Device IDs, IP addresses, and location details required for locally valid prescribing.

⚠ Health data is classified as **high-risk** under DPDPA. Blanket consents and silent approvals must be replaced with granular, verifiable opt-ins.



The Regulatory Shift: SPDI Rules vs. DPDPA 2023

A New Era of Privacy Enforcement

The Old Regime — SPDI Rules 2011

- Basic privacy policy publication was sufficient for compliance.
- Implied or bundled consent was widely accepted across platforms.
- Nominal, largely unenforced penalties for data breaches.

The New DPDPA Reality — 2023

- **Strict Opt-In:** Silent or pre-ticked checkmarks are illegal. Consent must be freely given, specific, informed, unconditional, and unambiguous.
- **High-Stakes Penalties:** Fines up to **₹250 Crores** for failing to prevent a personal data breach under Section 8.
- **ABDM Alignment:** Consent mechanisms must align with the Ayushman Bharat Digital Mission framework.

Core Challenge: The "Burden of Proof"

Section 6(10) — The Legal Vulnerability of Standard Systems

Under Section 6(10), the **Data Fiduciary** (the platform) bears the full burden of proving that valid consent was obtained from the **Data Principal** (the patient). Most legacy systems are dangerously ill-equipped for this standard.

Editable Database Logs

Standard SQL databases are mutable. Logs can be challenged in court as alterable, rendering them unreliable as legal evidence of consent.

No Notice Version Record

Systems fail to record the *exact notice version* a patient viewed at the moment they gave consent — a critical evidentiary gap.

Asymmetric Withdrawal

No mechanism exists to prove a patient withdrew consent and that downstream systems deleted the relevant records accordingly.

The Technical Solution: Granular Consent & Notice Architecture

Separation of Processing Purposes — Section 5 & 6

Every data collection touchpoint must be preceded by a clear, purpose-specific notice. Rather than a single monolithic consent form, a **Decoupled Purposes Registry** maps each consent to a distinct processing activity, making it both legally defensible and user-comprehensible.



Essential Consult Consent

Patient health data shared *only* with the consulting doctor for the active clinical encounter. Non-negotiable for service delivery.



Downstream Service Consent

Optional, explicit opt-in for sharing relevant data with diagnostic labs or partner pharmacies to fulfil a prescription.



Marketing Consent

Strictly separate opt-in for analytics pixels or promotional platforms. Cannot be bundled with clinical consent under any circumstances.



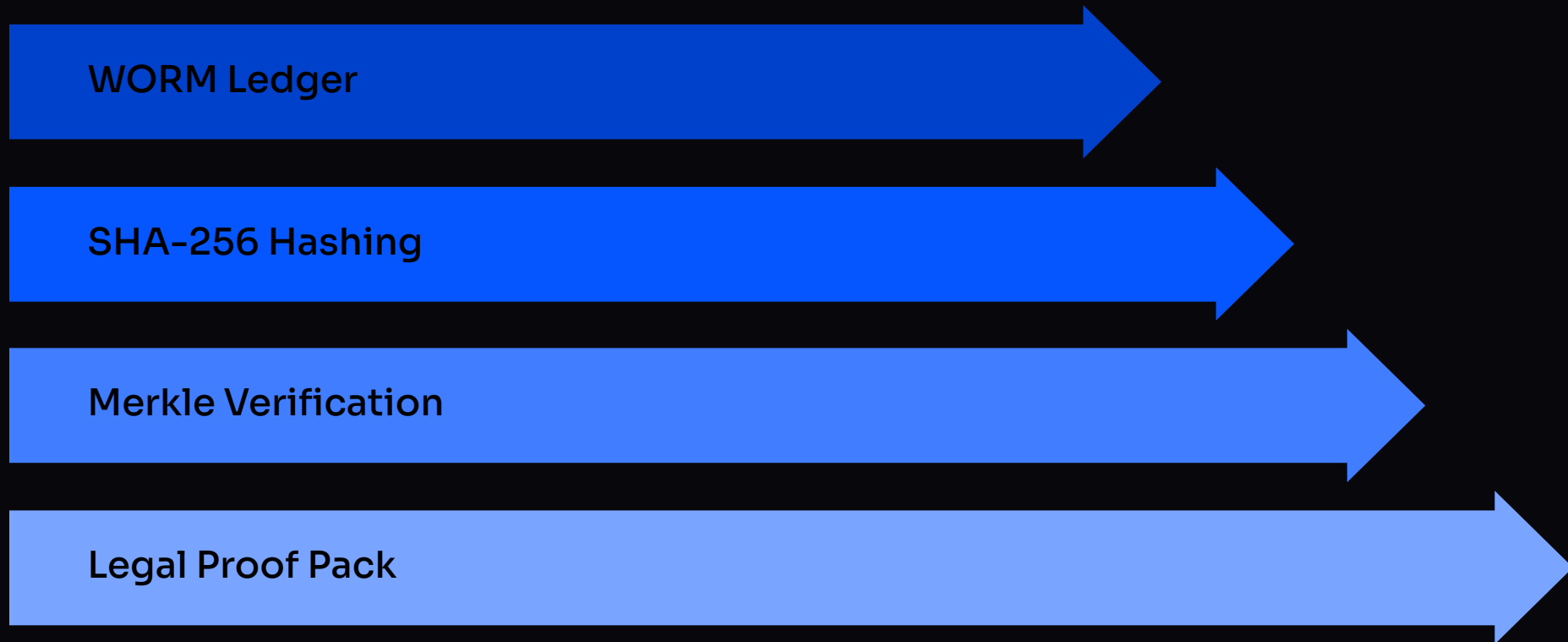
Dynamic Language Support

Notices dynamically translate into the patient's preferred Eighth Schedule language — Hindi, Tamil, Telugu, Marathi — per Section 6(3).

The Cryptographic Proof Vault

Building Tamper-Proof Evidence — Indian Evidence Act S. 65B

A legally robust compliance posture requires that consent records are not merely stored, but made **cryptographically unalterable**. The Proof Vault architecture ensures every consent event can withstand judicial scrutiny.



Upon request, the system automatically generates a court-admissible PDF bundle containing device metadata, the precise notice version hash, a certified timestamp, and the originating IP address — satisfying Section 65B of the Indian Evidence Act for electronic records.

Prior-Consent Enforcing Cookie & Tracker Manager

Eliminating Silent Tracking Scripts

Health platforms routinely embed third-party analytics and advertising scripts that fire *before* a patient has consented. Under DPDPA, this constitutes an unlawful processing act. A systematic, automated approach to tracker governance is essential.

01

Playwright Crawler Auditing

Automated crawlers regularly scan patient portals to identify all active trackers — including Google Tag Manager containers and Meta Pixel variants — and flag any uncatalogued scripts.

02

Prior-Consent Script Blocking

The client-side SDK intercepts and holds all non-essential scripts, preventing them from loading on the patient's browser **before** the consent banner interaction is completed.

03

Real-Time DPO Compliance Alerts

Data Protection Officers receive immediate warnings if a crawler scan detects unconsented tracking tags loading during a live patient session, enabling rapid remediation.

Significant Data Fiduciary (SDF) Obligations

Section 10 — Advanced Governance Controls

Platforms processing large volumes of sensitive health data are designated **Significant Data Fiduciaries** by the government — triggering a mandatory, elevated governance framework that goes beyond standard data fiduciary obligations.

1

Data Protection Officer (DPO)

Appointed, registered with the DPBI, and formally embedded — with contact details surfaced in every patient-facing notice to ensure accessibility and accountability.

2

DPIA Module

Automated Data Protection Impact Assessment templates for auditing new AI diagnostic features, third-party API integrations, or cloud migration projects before go-live.

3

Independent Audit Logging

Mandatory periodic external audits with immutable log export, verifying that technical safeguards remain effective and consistent with the platform's DPIA commitments.

- ❏ SDF designation is determined by the **Data Protection Board of India (DPBI)** and carries the highest tier of regulatory scrutiny under the DPDPA framework.

Posture Transformation & Business Metrics

Before and After DPDPA Shield Implementation — 30-Day Results

98%

Compliance Score

Posture rose from 35% (Non-Conformant) to 98% (Conformant) within 30 days of implementation.

80ms

Banner Load Time

Consent banner load times held under 80ms via dynamic edge routing — zero performance degradation for patients.

+15%

Registration Uplift

Tamil and Telugu translation availability increased user registration completion by 15% across southern states.

100%

Audit Readiness

Pre-compiled evidence files ensure absolute readiness for any sudden DPBI audit or regulatory inquiry.

✓ The platform is now fully positioned to operate with confidence under the DPDPA — protecting patients, satisfying regulators, and enabling sustainable growth.